INFORME DE INCIDENTE - VULNERABILIDAD SQL INJECTION EN DVWA
Conforme a ISO 27001

Fecha: 6 de Marzo 2026 | Evaluador: Especialista Seguridad | Ambiente: Laboratorio Aislado | Estado: Completado

I. DESCRIPCIÓN DEL INCIDENTE

Se descubrió una vulnerabilidad de inyección SQL (CWE-89) crítica (CVSS 9.8) en la aplicación DVWA instalada en Debian Linux con servidor Apache y base de datos MySQL/MariaDB.

Sistema Afectado: DVWA (Damn Vulnerable Web Application)
Vulnerabilidad: Inyección SQL en parámetro "User ID"
Módulo Afectado: SQL Injection (Nivel Low)
Impacto: Acceso no autorizado a credenciales de usuario

II. MÉTODO DE EXPLOTACIÓN

Payload Utilizado:
1' OR '1'='1

Este payload modifica la consulta SQL original haciendo que la condición WHERE siempre sea verdadera, devolviendo todos los registros de la tabla usuarios sin autenticación previa.

Payload Alternativo:
1 UNION SELECT username, password FROM users WHERE id=2

Este permite extraer credenciales específicas de la base de datos.

III. PASOS DE REPRODUCCIÓN

1. Acceder a: http://localhost/DVWA/login.php
2. Autenticación: Usuario: admin | Contraseña: password
3. Ir a sección "SQL Injection" (Nivel: Low)
4. En campo "User ID" inyectar: 1' OR '1'='1
5. Resultado: Acceso no autorizado a todos los usuarios

IV. IMPACTO POTENCIAL

- Confidencialidad: ALTO - Exposición de credenciales y datos personales
- Integridad: ALTO - Posibilidad de modificar/eliminar registros
- Disponibilidad: ALTO - Riesgo de corromper o destruir base de datos
- Impacto Empresarial: Comprometimiento total del sistema

V. RECOMENDACIONES

1. Implementar consultas parametrizadas (prepared statements)
2. Validación y sanitización estricta de entrada
3. Aplicar principio de mínimo privilegio en base de datos
4. Implementar Web Application Firewall (WAF) / ModSecurity
5. Realizar auditoría de seguridad de código

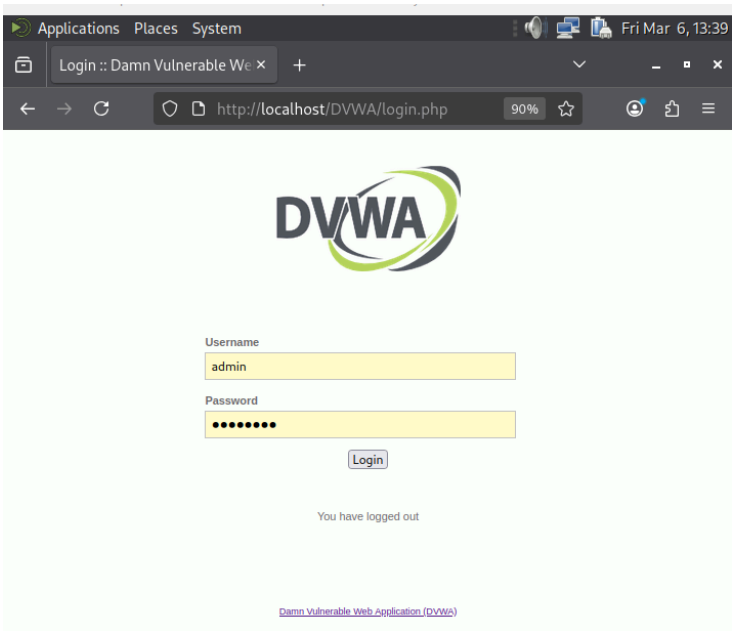
6. Implementar logging exhaustivo de accesos a BD
7. Capacitación del equipo en OWASP Top 10

VI. CONCLUSIÓN

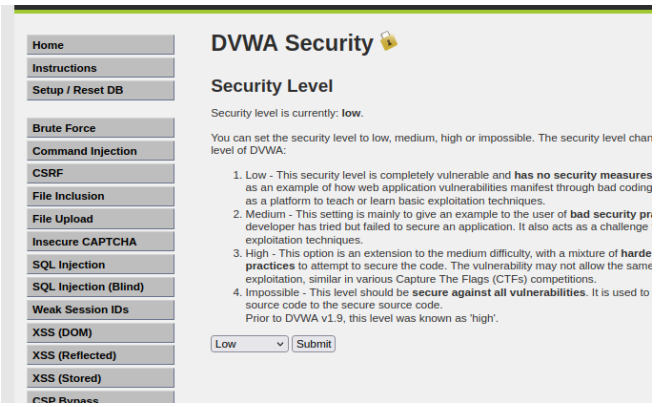
La vulnerabilidad de inyección SQL representa un riesgo crítico que debe ser corregido inmediatamente. La implementación de los controles recomendados es esencial para proteger la confidencialidad e integridad de los datos de la aplicación.

ANEXO A: CAPTURAS DE PANTALLA DE LA VULNERABILIDAD

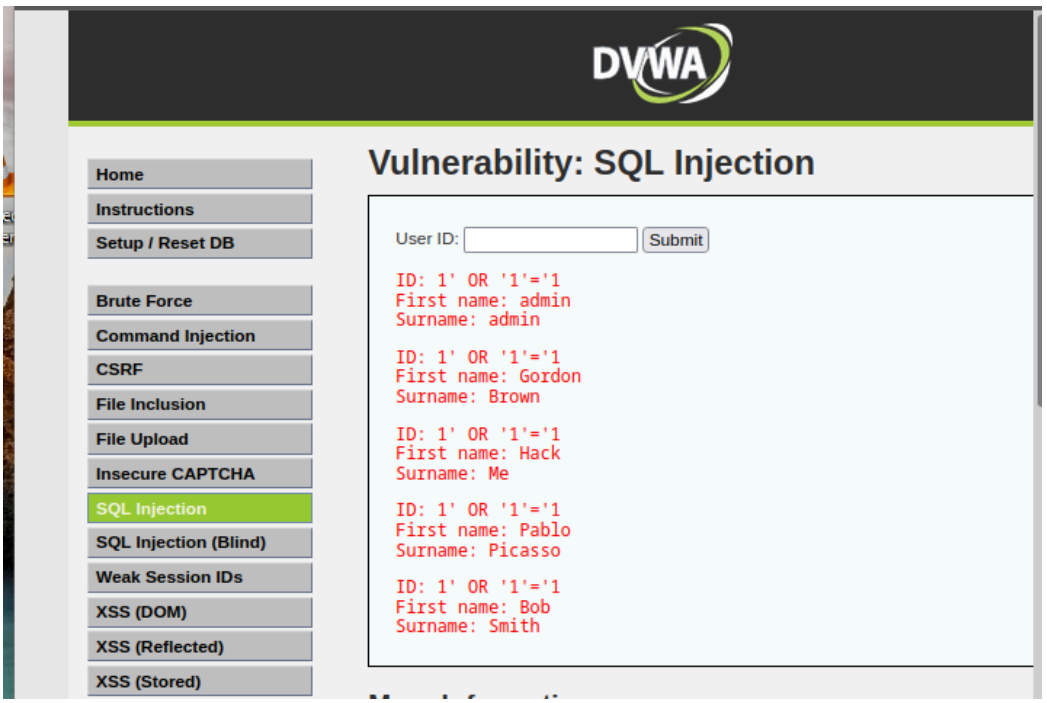
[CAPTURA 1 - Pantalla de Login DVWA]
Muestra: Formulario de autenticación en http://localhost/DVWA/login.php
Credenciales: Usuario = admin, Contraseña = password



[CAPTURA 2 - Panel de SQL Injection - Nivel Low]
Muestra: Módulo de SQL Injection con campo de entrada "User ID"
Este campo acepta input sin validación de seguridad



[CAPTURA 3 - Inyección SQL: Payload 1' OR '1'='1]
Muestra: Resultado de la inyección mostrando TODOS los usuarios
Datos expuestos: admin, Gordon, Hack, Pablo, 1337


DVWA
Home
Instructions
Setup / Reset DB
Brute Force
Command Injection
CSRF
File Inclusion
File Upload
Insecure CAPTCHA
SQL Injection
SQL Injection (Blind)
Weak Session IDs
XSS (DOM)
XSS (Reflected)
XSS (Stored)
Vulnerability: SQL Injection
User ID:
Submit
ID: 1' OR '1'='1
First name: admin
Surname: admin
ID: 1' OR '1'='1
First name: Gordon
Surname: Brown
ID: 1' OR '1'='1
First name: Hack
Surname: Me
ID: 1' OR '1'='1
First name: Pablo
Surname: Picasso
ID: 1' OR '1'='1
First name: Bob
Surname: Smith